

UNIT-3

NETWORK SECURITY

3.1 WORKING PRINCIPLES OF FIREWALL

3.1.1 Introduction to Firewall

A Firewall is a hardware or software to prevent a private computer or a network of computers from unauthorized access, it acts as a filter to prevent unauthorized users from accessing private computers and networks. It is a vital component of network security. It is the first line of defense for network security. A firewall has a set of rules which are applied to each packet. The rules decide if a packet can pass or whether it is discarded. It filters network packets and stops malware from entering the user's computer or network by blocking access and preventing the user from being infected. A firewall establishes a barrier between secured internal networks and outside untrusted networks, such as the Internet.

3.1.2 Five Principles of Firewall Design

Firewall design principles are critical to protect your private network and maximize your network security. Here are five principles you can use when establishing your firewall and implementing security policies.

1) Develop a Solid Security Policy

Having a proper security policy is an essential part of designing a firewall. Without it in place, it's a headache to allow users to navigate the company network and restrict intruders. This proper security policy will also help you know the proper protocol if there is a security breach and it is useful for reporting security threats. A properly developed security policy can protect you. A solid security policy includes guidance on proper internet protocol, preventing users from using devices on public networks and recognizing external threats. Simply having a security policy is only the first step. In addition to establishing security policies, one should have frequent training and refreshers for all employees.

2) Use a Simple Design

If you have a complex design, you'll need to find complex solutions anytime a problem arises. A simple design helps alleviate some of the pain you may feel when a problem comes up. Also, complex designs are more likely to suffer from configuration errors that can open paths for external attacks.

3) Choose the Right Device

You need to have the right tools to do the job. If you use the wrong device, you have the wrong tools and are at a disadvantage from the start. Using the right part that fits your design will help you create the best firewall for your network.

4) Build a Layered Defense

Firewalls should have layers to properly protect your network. A multi-layered defense creates a complicated protection system that hackers can't easily break through. Creating layers builds an effective defense and will keep your network safe.

5) Build Protection Against Internal Threats

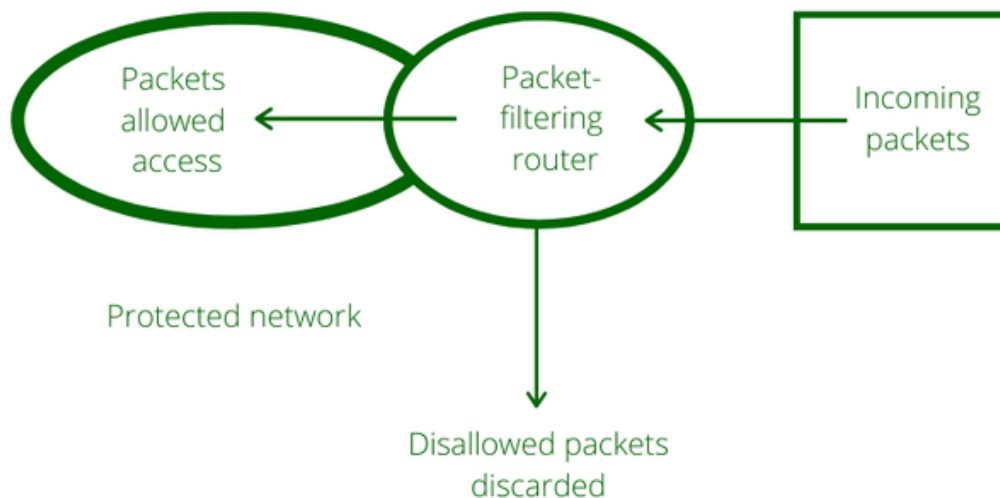
Don't just focus on attacks from external sources. A large percentage of data breaches are the result of internal threats and carelessness. Mistakes made by those internally can open your network to attacks from outside sources. Implementing proper security solutions for your internal network can help prevent this from happening. Something as simple as accessing a web server can expose your network if you aren't protected internally as well as externally.

3.1.3 Types of Firewalls:

There are five main types of firewalls depending upon their operational method:

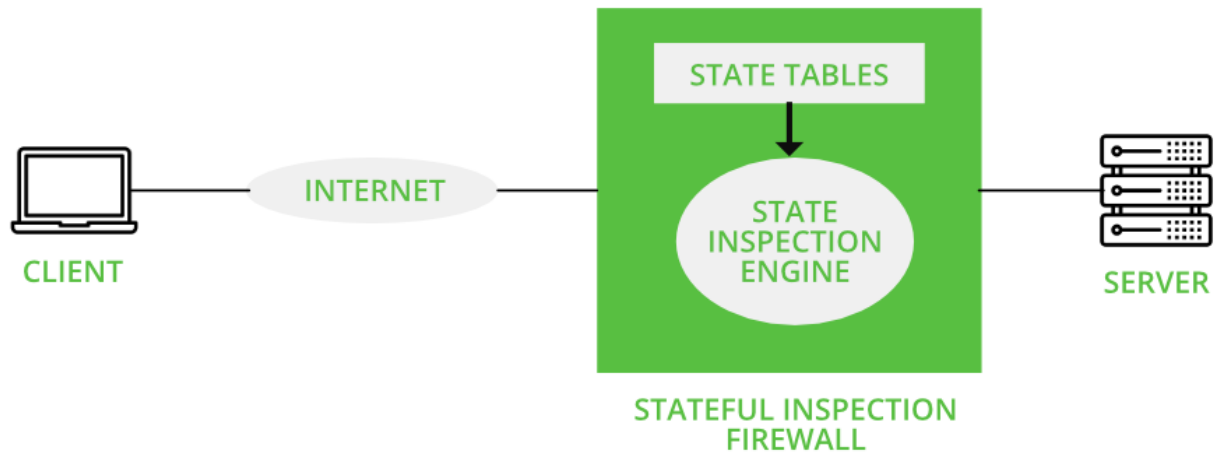
- 1) Stateless or Packet Filtering Firewall
- 2) Stateful Inspection Firewall
- 3) Circuit-Level Gateway
- 4) Application-Level Gateway
- 5) Next-Generation Firewall (NGFW)

1) Stateless or Packet Filtering Firewall:



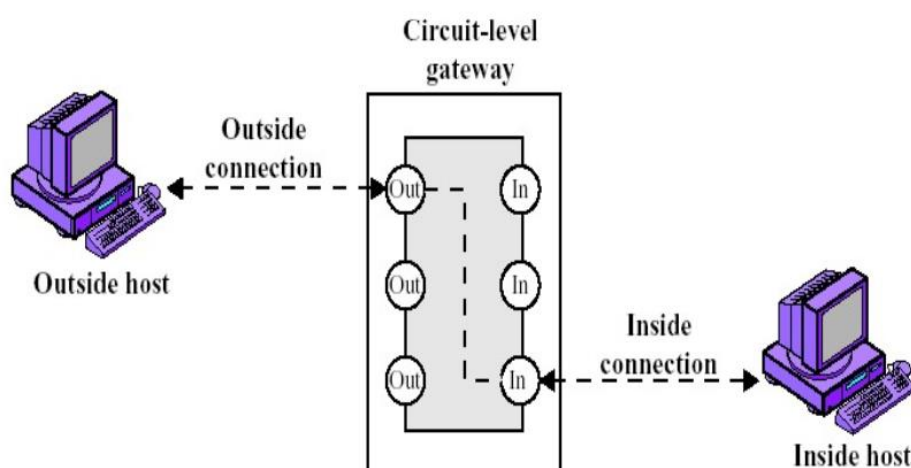
A packet filtering firewall protects the network by analyzing traffic in the transport protocol layer where applications can communicate with each other using specific protocols like Transmission Control Protocol (TCP) and User Datagram Protocol (UDP). The firewall examines the data packets at this layer, looking for malicious code that can infect the network or device. If a data packet is identified as a potential threat, the firewall rejects it. Small businesses that need basic protection from existing cyber threats can benefit from a packet-filtering firewall. Packet-filtering firewalls analyze surface-level details only and do not open the packet to examine the actual data (content payload). They check each one in isolation for destination and IP address, packet type, port number and network protocols but not in context with current traffic streams.

2) Stateful Inspection Firewall:



Stateful inspection firewalls operate at the gateway between systems behind the firewall and resources outside the enterprise network. Stateful inspection firewalls are situated at Layers 3 and 4 of the OSI model. State-aware firewalls examine each packet (stateful inspection) and track and monitor the state of active network connections while analyzing incoming traffic for potential risks. The “state” is the most recent or immediate status of a process or application. Stateful firewalls can detect attempts by unauthorized individuals to access a network, as well as analyze the data within packets to see if they contain malicious code. They are very effective at defending the network against denial of service (DoS) attacks. It is important to monitor the state and context of network communications because this information can be used to identify threats either based on where they are coming from, where they are going, or the content of their data packets. This method offers more security than either packet filtering or circuit monitoring alone but exacts a greater toll on network performance.

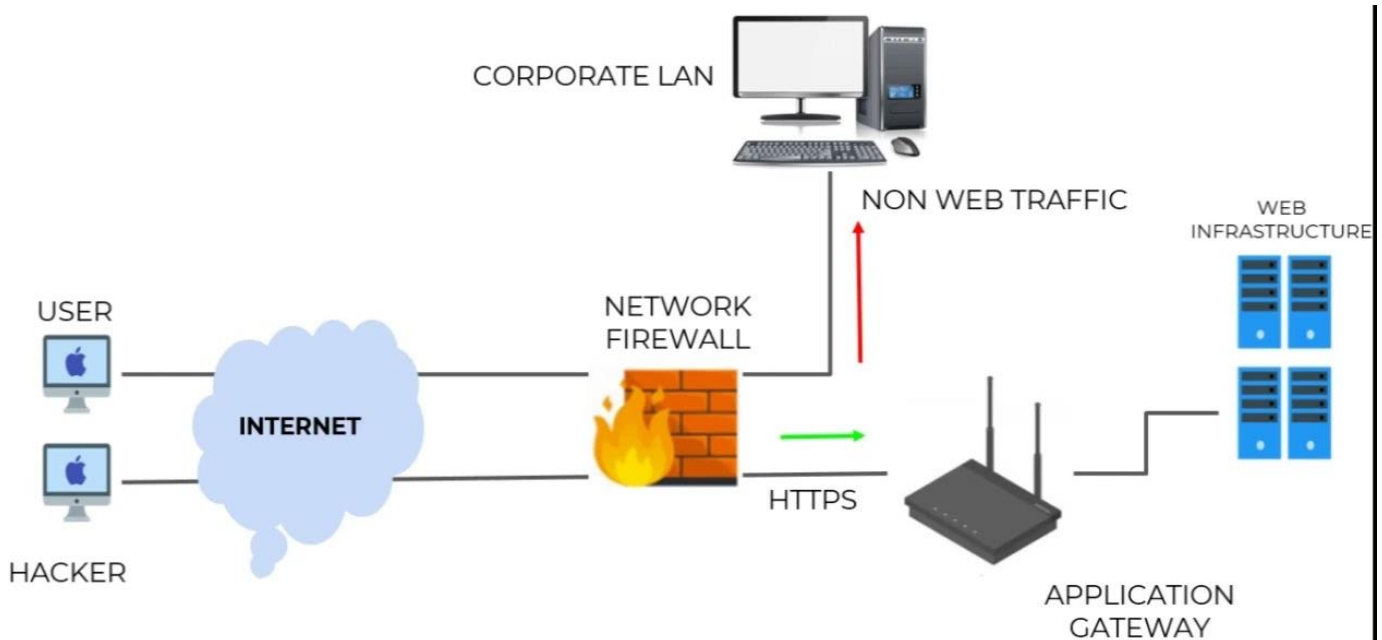
3) Circuit-level Gateway:



Circuit-level gateways operate at the session layer of the OSI model. In the OSI model, a handshake must occur before information can be passed from one cyber entity to another. Circuit-level gateways determine the security of an established connection between the transport layer and the application layer of the TCP/Internet Protocol (TCP/IP) stack by monitoring TCP handshakes between local and remote hosts. While circuit-level gateways have minimal impact on network performance, a data packet containing malware can bypass a

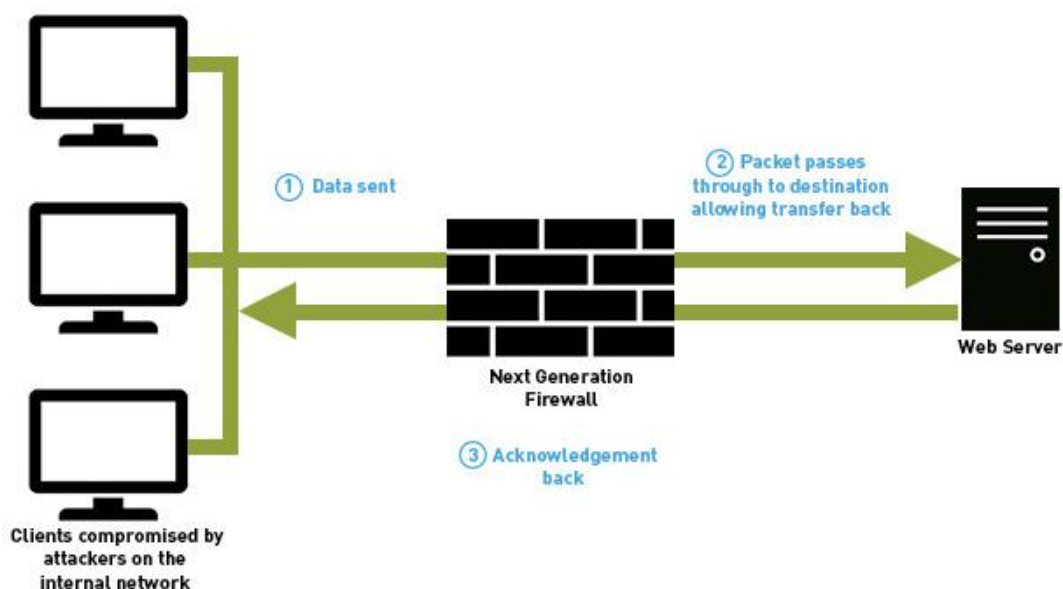
circuit-level gateway easily even if it has a legitimate TCP handshake. This is because circuit-level gateways do not filter the content in data packets. To fill this gap, circuit-level gateways are often paired with another type of firewall that performs content filtering.

4) Application-level Gateway:



It is also referred to as a “proxy firewall” and serves as an intermediate between internal and external systems. An application-level gateway operates at the application layer, the highest of the OSI model. It employs deep packet inspection (DPI) on incoming traffic to check both data packet payloads (content) and headers. This firewall makes sure that only valid data exists at the application level before allowing it to pass through. Application-level gateways follow a set of application-specific policies to determine which communications are allowed to pass to and from an application. They help protect a network by masking clients’ requests before sending them to the host. When network anonymity is required, application-level gateways are often in play. They are ideal for securing web apps from bad actors (malicious intent).

5) Next-Generation Firewall (NGFW):



A Next-Generation Firewall (NGFW) is the only type of firewall that provides the capabilities to protect modern businesses against emerging cyber threats. As malware and threats have become more difficult to detect at the access point, NGFW security has evolved to span the network and monitor behavior and intent. NGFWs provide functions like deep-packet inspection, intrusion prevention (IPS), advanced malware detection, application control and provide overall network visibility through inspection of encrypted traffic. They can be found anywhere from an on-premises network edge to its internal boundaries and can also be employed on public or private cloud networks. NGFWs CPU-intensive capabilities include decryption at a very high-performance level, deep-packet inspection post decryption, detection of malicious URLs, identification of command-and-control activities and download of malware and threat correlation. Due to these advanced security capabilities, NGFWs are critical for heavily regulated industries such as finance or healthcare and are often integrated with other security systems and SIEMs for end-to-end surveillance and reporting.

3.1.4 Characteristics of Firewall

- 1) **Physical Barrier:** A firewall does not allow any external traffic to enter a system or a network without its allowance. A firewall creates a choke point for all the external data trying to enter the system or network and hence can easily block access if needed.
- 2) **Multi-Purpose:** A firewall has many functions other than security purposes. It configures domain names and Internet Protocol (IP) addresses. It also acts as a network address translator. It can act as a meter for internet usage.
- 3) **Flexible Security Policies:** Different local systems or networks need different security policies. A firewall can be modified according to the requirement of the user by changing its security policies.
- 4) **Security Platform:** It provides a platform from which any alert to the issue related to security or fixing issues can be accessed. All the queries related to security can be kept under check from one place in a system or network.
- 5) **Access Handler:** Determines which traffic needs to flow first according to priority or can change for a particular network or system. Specific action requests may be initiated and allowed to flow through the firewall.

3.1.5 Advantages of Firewall

- 1) **Blocks Infected Files:** While surfing the internet we encounter many unknown threats. Any friendly-looking file might have malware in it. The firewall neutralizes this kind of threat by blocking file access to the system.
- 2) **Stop Unwanted Visitors:** A firewall does not allow a cracker to break into the system through a network. A strong firewall detects the threat and then stops the possible loophole that can be used to penetrate through security into the system.

- 3) **Prevents Email spamming:** In this too many emails are sent to the same address leading to the server crashing. A good firewall blocks the spammer source and prevents the server from crashing.
- 4) **Control of Network Access:** By limiting access to specified individuals or groups for particular servers or applications, firewalls can be used to restrict access to particular network resources or services.
- 5) **Monitoring of Network Activity:** Firewalls can be set up to record and keep track of all network activity. This information is essential for identifying and looking into security problems and other kinds of shady behavior.

3.1.6 Disadvantages of Firewall

- 1) **Infected Files:** In the modern world, we come across various kinds of files through emails or the internet. Most of the files are executable under the parameters of an operating system. It becomes impossible for the firewall to keep track of all the files flowing through the system.
- 2) **User Restriction:** Restrictions and rules implemented through a firewall make a network secure but they can make work less effective when it comes to a large organization or a company. Even making a slight change in data can require a permit from a person of higher authority making work slow. The overall productivity drops because of all of this.
- 3) **System Performance:** A software-based firewall consumes a lot of resources of a system. Using the RAM and consuming the power supply leaves very less resources for the rest of the functions or programs. The performance of a system can experience a drop. On the other hand, a hardware firewall does not affect the performance of a system much, because it's very less dependent on the system resources.
- 4) **Complexity:** Setting up and keeping up a firewall can be time-consuming and difficult, especially for bigger networks or companies with a wide variety of users and devices.
- 5) **Cost:** Purchasing many devices or add-on features for a firewall system can be expensive, especially for businesses.

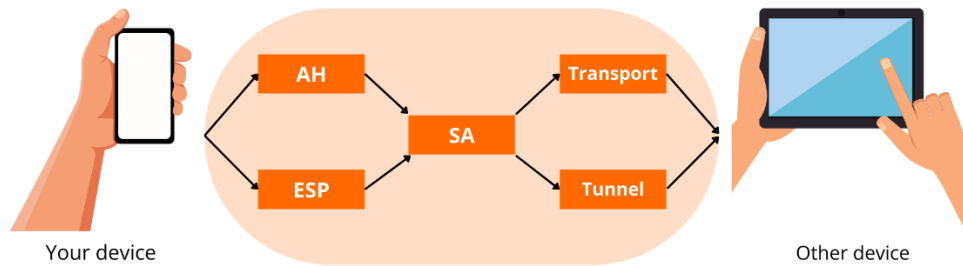
3.2 INTERNET PROTOCOL SECURITY AND ITS USE IN SECURE COMMUNICATION

3.2.1 Introduction

IPsec is a set of protocols to secure internet communication at the network layer. It was developed by the Internet Engineering Task Force (IETF) to provide a secure way to exchange data over the Internet, ensuring that sensitive information is protected from unauthorized access, interception, or modification.

IPsec is the short acronym for Internet Protocol Security. The "IP" stands for Internet Protocol, which is the main routing protocol used on the Internet for sending data to its destination using IP addresses. The "sec" stands for secure, as it provides encryption and authentication to the data transmission process, making it more secure.

IPSEC



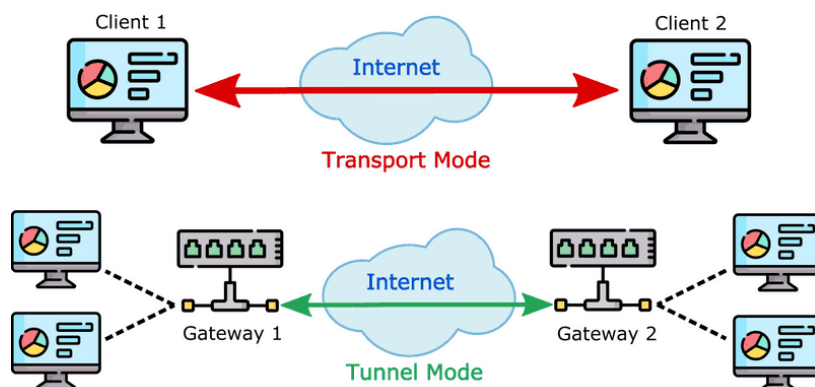
IPsec uses a variety of protocols to establish secure connections and protect data during transmission. IPsec is not one protocol but a suite of protocols. The suite includes the following:

- 1) Authentication Header (AH):** It provides data integrity and authentication and ensures that the transmitted data has not been modified or tampered with. Yet, it does not encrypt data.
- 2) Encapsulating Security Protocol (ESP):** It encrypts both the IP header and the payload of each packet unless transport mode is used, in which case only the payload is encrypted. In addition, ESP adds its header and a trailer to each data packet.
- 3) Security Association (SA):** An SA is a set of security parameters defining how two devices communicate securely. It includes information such as the encryption algorithm, authentication method, and key size. One of the most commonly used SA protocols is the Internet Key Exchange (IKE). IPsec uses port 500 for its IKE (Internet Key Exchange) protocol.

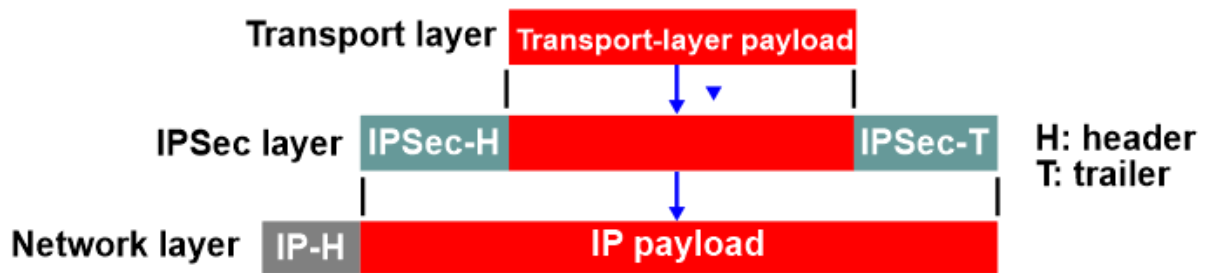
3.2.2 Modes of IPsec

IPsec operates in one of two different modes: Transport Mode or Tunnel Mode

IPsec Modes

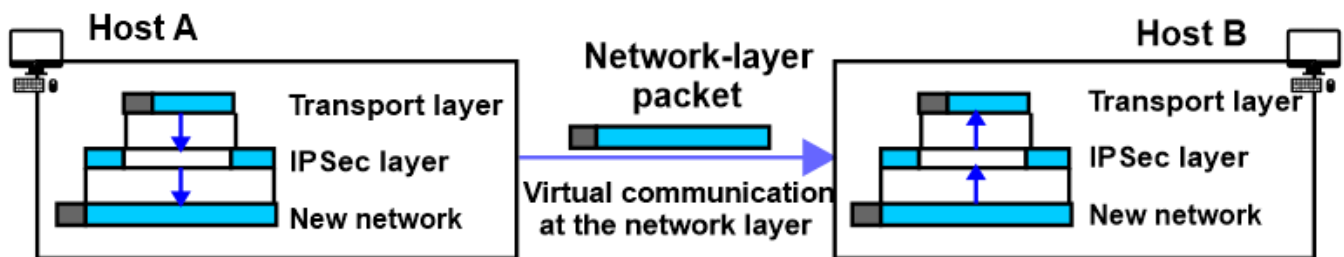


Transport Mode



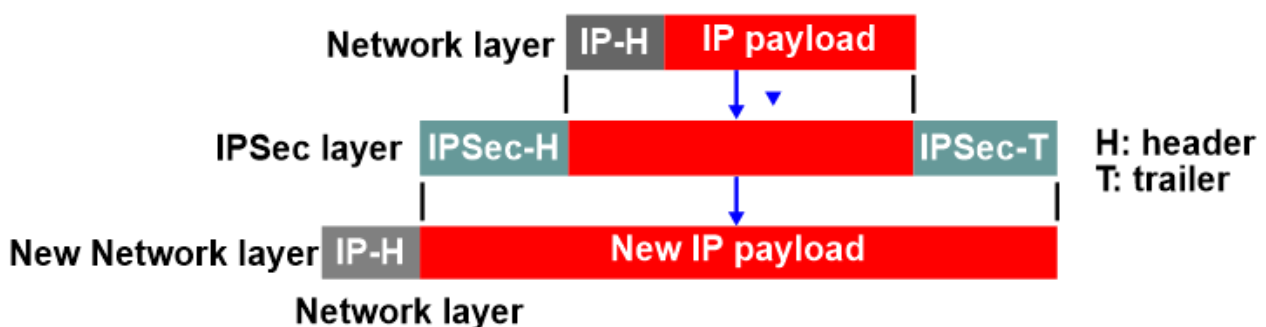
In the transport mode, IPSec protects what is delivered from the transport layer to the network layer. In other words, the transport mode protects the network layer payload, the payload to be encapsulated in the network layer. Note that the transport mode does not protect the IP header. The transport mode does not protect the whole IP packet; it protects only the packet from the transport layer (the IP layer payload). In this mode, the IPSec header and trailer are added to the information coming from the transport layer. The IP header is added later.

Transport mode in action



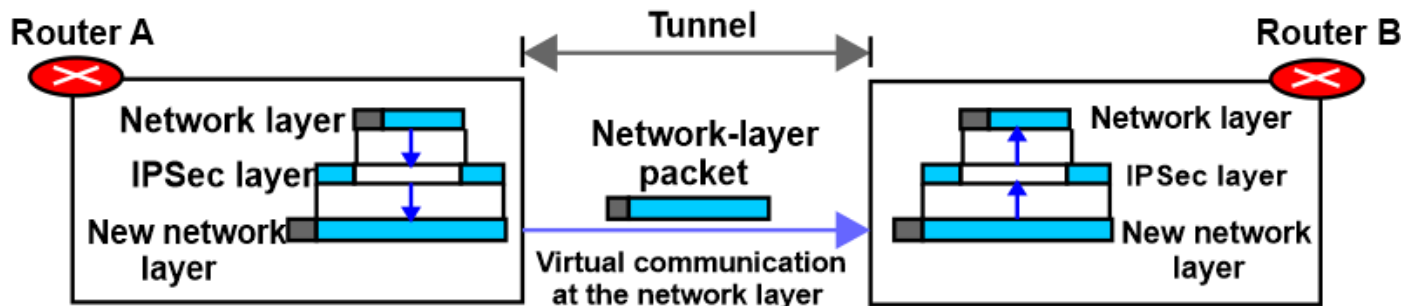
The transport mode is normally used when we need host-to-host (end-to-end) protection of data. The sending host uses IPSec to authenticate and/or encrypt the payload delivered from the transport layer. The receiving host uses IPSec to check the authentication and/or decrypt the IP packet and deliver it to the transport layer. The figure above shows this concept.

Tunnel Mode



In the tunnel mode, IPSec protects the entire IP packet. It takes an IP packet, including the header, applies IPSec security methods to the entire packet, and then adds a new IP header as shown in figure below. The new IP header, as we will see shortly, has different information than the original IP header.

Tunnel mode in action



The tunnel mode is normally used between two routers, between a host and a router, or between a router and a host as shown in figure above. In other words, we use the tunnel mode when either the sender or the receiver is not a host. The entire original packet is protected from intrusion between the sender and the receiver. It's as if the whole packet goes through an imaginary tunnel. IPsec in tunnel mode protects the original IP header.

3.2.3 Features of IPsec

- 1) **Authentication:** IPsec provides authentication of IP packets using digital signatures or shared secrets. This helps ensure that the packets are not tampered with or forged.
- 2) **Confidentiality:** IPsec provides confidentiality by encrypting IP packets, preventing eavesdropping on the network traffic.
- 3) **Integrity:** IPsec provides integrity by ensuring that IP packets have not been modified or corrupted during transmission.
- 4) **Key management:** IPsec provides key management services, including key exchange and key revocation, to ensure that cryptographic keys are securely managed.
- 5) **Tunneling:** IPsec supports tunneling, allowing IP packets to be encapsulated within another protocol, such as GRE (Generic Routing Encapsulation) or L2TP (Layer 2 Tunneling Protocol).
- 6) **Flexibility:** IPsec can be configured to provide security for a wide range of network topologies, including point-to-point, site-to-site, and remote access connections.
- 7) **Interoperability:** IPsec is an open standard protocol, which means that it is supported by a wide range of vendors and can be used in heterogeneous environments.

3.2.4 Advantages of IPsec

- 1) **Strong security:** IPsec provides strong cryptographic security services that help protect sensitive data and ensure network privacy and integrity.
- 2) **Wide compatibility:** IPsec is an open standard protocol that is widely supported by vendors and can be used in heterogeneous environments.

3) Flexibility: IPSec can be configured to provide security for a wide range of network topologies, including point-to-point, site-to-site, and remote access connections.

4) Scalability: IPSec can be used to secure large-scale networks and can be scaled up or down as needed.

5) Improved Network Performance: IPSec can help improve network performance by reducing network congestion and improving network efficiency.

3.2.5 Disadvantages of IPSec

1) Configuration complexity: IPSec can be complex to configure and requires specialized knowledge and skills.

2) Compatibility issues: IPSec can have compatibility issues with some network devices and applications, which can lead to interoperability problems.

3) Performance impact: IPSec can impact network performance due to the overhead of encryption and decryption of IP packets.

4) Key management: IPSec requires effective key management to ensure the security of the cryptographic keys used for encryption and authentication.

5) Limited protection: IPSec only protects IP traffic and other protocols such as ICMP, DNS and routing protocols may still be vulnerable to attacks.

3.2.6 Difference between IPv4 and IPv6

Parameters	IPv4	IPv6
Address length	IPv4 is a 32-bit address.	IPv6 is a 128-bit address.
Fields	IPv4 is a numeric address that consists of 4 fields which are separated by a dot (.).	IPv6 is an alphanumeric address that consists of 8 fields, which are separated by a colon.
Classes	IPv4 has 5 different classes of IP addresses that includes Class A, Class B, Class C, Class D and Class E.	IPv6 does not contain classes of IP addresses.
Number of IP addresses	IPv4 has a limited number of IP addresses.	IPv6 has a large number of IP addresses.
VLSM	It supports VLSM (Virtual Length Subnet Mask). Here, VLSM means that Ipv4 converts IP addresses into a subnet of different sizes.	It does not support VLSM.
Address configuration	It supports manual and DHCP configuration.	It supports manual, DHCP, auto-configuration, and renumbering.

NETWORK SECURITY & MANAGEMENT

Address space	It generates 4 billion unique addresses	It generates 340 undecillion unique addresses.
End-to-end connection integrity	In IPv4, end-to-end connection integrity is unachievable.	In the case of IPv6, end-to-end connection integrity is achievable.
Security features	In IPv4, security depends on the application. This IP address is not developed in keeping the security feature in mind.	In IPv6, IPSEC is developed for security purposes.
Address representation	In IPv4, the IP address is represented in decimal.	In IPv6, the representation of the IP address in hexadecimal.
Fragmentation	Fragmentation is done by the senders and the forwarding routers.	Fragmentation is done by the senders only.
Packet flow identification	It does not provide any mechanism for packet flow identification.	It uses flow label field in the header for the packet flow identification.
Checksum field	The checksum field is available in IPv4.	The checksum field is not available in IPv6.
Transmission scheme	IPv4 is broadcasting.	On the other hand, IPv6 is multicasting, which provides efficient network operations.
Encryption and Authentication	It does not provide encryption and authentication.	It provides encryption and authentication.
Number of octets	It consists of 4 octets.	It consists of 8 fields, and each field contains 2 octets. Therefore, the total number of octets in IPv6 is 16.

3.3 VARIOUS TYPES OF IDSs

3.3.1 Introduction

An Intrusion Detection System (IDS) is a system that monitors network traffic for suspicious activity and issues alerts when such activity is discovered. It is a software application that scans a network or a system for harmful activity or policy breaches. Any malicious venture or violation is normally reported either to an administrator or collected centrally using a Security Information and Event Management (SIEM) system. A SIEM system integrates outputs from multiple sources and uses alarm filtering techniques to differentiate malicious activity from false alarms.

Although intrusion detection systems monitor networks for potentially malicious activity, they are also disposed to false alarms. Hence, organizations need to fine-tune their IDS products when they first install them. It means properly setting up the intrusion detection systems to recognize what normal traffic on the network looks like as compared to malicious activity.

IDS and firewall both are related to network security but an IDS differs from a firewall as a firewall looks outwardly for intrusions to stop them from happening. Firewalls restrict access between networks to prevent intrusion and if an attack is from inside the network it doesn't signal. An IDS describes a suspected intrusion once it has happened and then signals an alarm. The most optimal and common position for an IDS is behind the firewall. Although this position varies considering the network.

3.3.2 Detection Methods of IDS

1) Signature-based Method:

Signature-based IDS detects the attacks based on specific patterns such as the number of bytes or number of 1's or number of 0's in the network traffic. It also detects based on the already known malicious instruction sequence that is used by the malware. The detected patterns in the IDS are known as signatures. Signature-based IDS can easily detect the attacks whose pattern (signature) already exists in the system, but it is quite difficult to detect new malware attacks as their pattern (signature) is not known.

2) Anomaly-based Method:

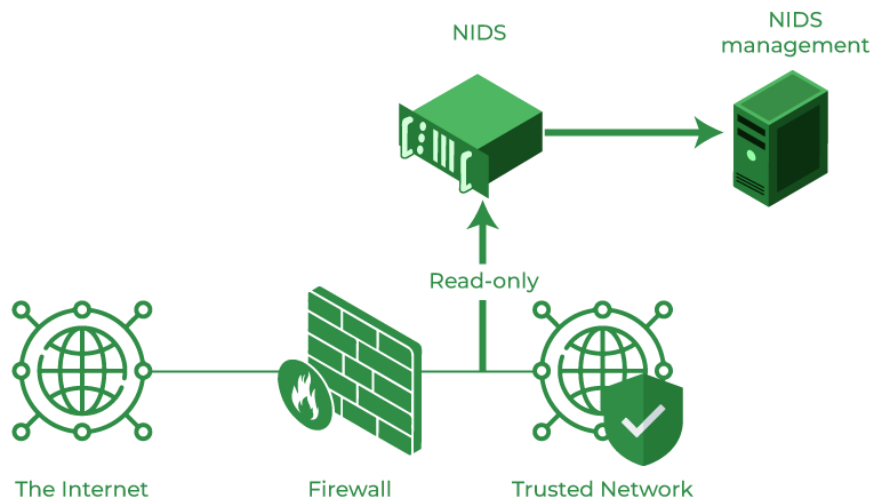
Anomaly-based IDS was introduced to detect unknown malware attacks as new malware is developed rapidly. In anomaly-based IDS there is the use of machine learning to create a trustful activity model and anything coming is compared with that model and it is declared suspicious if it is not found in the model. Machine learning-based method has a better- generalized property in comparison to signature-based IDS as these models can be trained according to the applications and hardware configurations.

3.3.3 Classification of IDS

Intrusion Detection Systems are classified into 5 types:

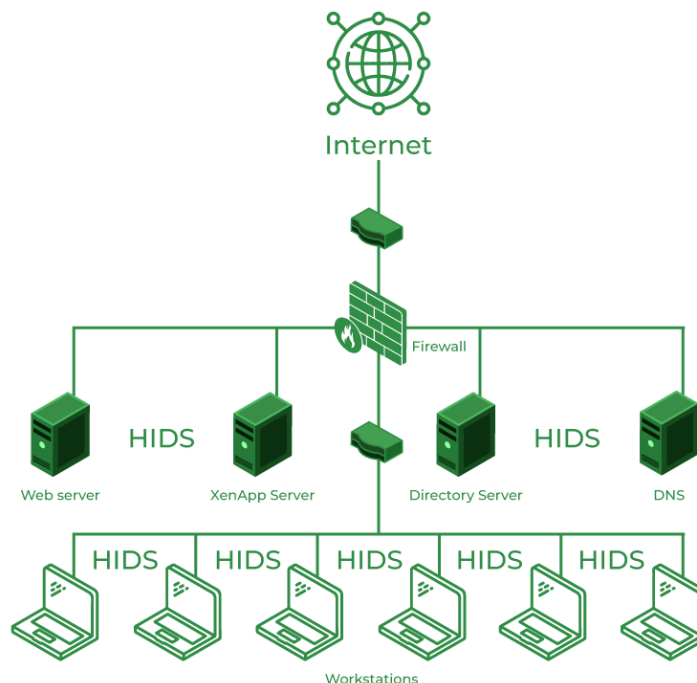
1) Network Intrusion Detection System (NIDS):

Network intrusion detection systems (NIDS) are set up at a planned point within the network to examine traffic from all devices on the network. It performs an observation of passing traffic on the entire subnet and matches the traffic that is passed on the subnets to the collection of known attacks. Once an attack is identified or abnormal behavior is observed, the alert can be sent to the administrator. An example of a NIDS is installing it on the subnet where firewalls are located in order to see if someone is trying to crack the firewall.



2) Host Intrusion Detection System (HIDS):

Host Intrusion Detection System (HIDS) run on independent hosts or devices on the network. A HIDS monitors the incoming and outgoing packets from the device only and will alert the administrator if suspicious or malicious activity is detected. It takes a snapshot of existing system files and compares it with the previous snapshot. If the analytical system files were edited or deleted, an alert is sent to the administrator to investigate. An example of HIDS usage can be seen on mission-critical machines, which are not expected to change their layout.



3) Protocol-based Intrusion Detection System (PIDS):

A Protocol-Based Intrusion Detection System (PIDS) comprises a system or agent that would consistently reside at the front end of a server, controlling and interpreting the protocol between a user/device and the server. It is trying to secure the web server by regularly monitoring the HTTPS protocol stream and accepting

the related HTTP protocol. As HTTPS is unencrypted and before instantly entering its web presentation layer then this system would need to reside in this interface, between to use the HTTPS.

4) Application Protocol-based Intrusion Detection System (APIDS):

An Application Protocol-Based Intrusion Detection System (APIDS) is a system or agent that generally resides within a group of servers. It identifies the intrusions by monitoring and interpreting the communication on application-specific protocols. For example, this would monitor the SQL protocol explicitly to the middleware as it transacts with the database in the web server.

5) Hybrid Intrusion Detection System:

Hybrid intrusion detection system is made by the combination of two or more approaches to the intrusion detection system. In the hybrid intrusion detection system, the host agent or system data is combined with network information to develop a complete view of the network system. The hybrid intrusion detection system is more effective in comparison to the other intrusion detection system. Prelude is an example of Hybrid IDS.

3.4 DISTINGUISH HOST-BASED IDS AND NETWORK-BASED IDS

Parameters	HIDS	NIDS
Full Form	Host Intrusion Detection System.	Network Intrusion Detection System.
Type	It doesn't work in real-time.	It operates in real-time.
Concern	HIDS is related to just a single system, as the name suggests it is only concerned with the threats related to the Host system/computer.	NIDS is concerned with the entire network system, NIDS examines the activities and traffic of all the systems in the network.
Installation Point	HIDS can be installed on every computer or server i.e., anything that can serve as a host.	NIDS being concerned with the network is installed at places like routers or servers as these are the main intersection points in the network system.
Execution Process	HIDS operates by taking a snapshot of the current status of the system and comparing it against some already stored	NIDS works in real-time by closely examining the data flow and immediately reporting anything unusual.

	malicious tagged snapshots stored in the database, this clearly shows that there is a delay in its operation and activities.	
Information about attack	HIDS are more informed about the attacks as they are associated with system files and processes.	As the network is very large making it hard to keep track of the integrating functionalities, they are less informed of the attacks.
Ease of Installation	As it needs to be installed on every host, the installation process can be tiresome.	Few installation points make it easier to install NIDS.
Response Time	Response time is slow.	Response time is fast.

3.5 HIDS AND NIDS COMPONENTS

- 1) Data Collectors:** Using either agents or an agentless approach, your HIDS deploys sensors that collect data from hosts.
- 2) Data Storage:** After being collected, the data is usually aggregated and stored in a central location. The data is retained at least as long as is necessary to analyze it, although organizations may also choose to keep the data on hand so they can reference it at a later time if desired.
- 3) Analytics Engine:** The HIDS uses an analytics engine to process and evaluate the various data sources that it collects. The purpose of analytics is to look for patterns or anomalies, and then assess the likelihood that they are the result of security risks or attacks.

3.6 ADVANTAGES AND DISADVANTAGES OF HIDS, NIDS

Advantages of HIDS:

- 1) Verifies success or failure of an attack:** Since a host-based IDS uses system logs containing events that have occurred, they can determine whether an attack occurred or not.
- 2) Monitors System Activities:** A host-based IDS sensor monitors user and file access activity including file accesses, changes to file permissions, attempts to install new executables, etc.
- 3) Detects attacks that a network-based IDS fails to detect:** Host-based systems can detect attacks that network-based IDS sensors fail to detect. For example, if an unauthorized user makes changes to system files from the system console, this kind of attack goes unnoticed by the network sensors.
- 4) Near real-time detection and response:** Although host-based IDS do not offer true real-time response, it can come very close if implemented correctly.

5) Lower entry cost: Host-based IDS sensors are far cheaper than network-based IDS sensors.

Disadvantages of HIDS:

- 1) Host-based IDSs are harder to manage, as information must be configured and managed for every host.
- 2) The information sources for host-based IDSs reside on the host targeted by attacks, the IDSs may be attacked and disabled as part of the attack.
- 3) Host-based IDSs are not well suited for detecting network scans or other such surveillance that targets an entire network.
- 4) Host-based IDSs can be disabled by certain denial-of-service attacks.

Advantages of NIDS:

- 1) A few well-placed network-based IDS can monitor a large network.
- 2) The deployment of NIDSs has little impact on an existing network.
- 3) NIDSs can be made very secure against attack and even made invisible to many attackers.

.

Disadvantages of NIDS:

- 1) NIDSs may have difficulty possessing all packets in a large or busy network and, therefore, may fail to recognize an attack launched during a period of high traffic.
- 2) Many of the advantages of NIDSs don't apply to more modern switch-based networks.
- 3) NIDSs cannot analyze encrypted information. This problem is increasing as organizations and attackers use virtual private networks.
- 4) Most NIDSs cannot tell whether or not an attack was successful; they can only find that an attack was initiated.